

PASTA worksheet

Stages	Sneaker company
I. Define business and security objectives	- Account and security logins stored securely - Safe Back-End Processing - Safe PII storing - Secure payment request and stored payment data - Secure Inventory Processing
II. Define the technical scope	List of technologies used by the application: - Application programming interface (API) - Public key infrastructure (PKI) - SHA-256 - SQL We will work with an high priority on the SQL technology, as it seems unclear if Prepared statements are in action and it represents a high risk for potential SQL injections from possibly threat actors. Both PKI and SHA-256 give a good lever of security by encryption and hashing processes.
III. Decompose application	Sample data flow diagram In the Sample Data flow diagram we can see how the flow moves from the user searching for sneakers on the search bar, activating the Product search process and sending an SQL query to the listing of current inventory stored in the Database.
IV. Threat analysis	List 2 types of threats in the PASTA worksheet that are risks to the information being handled by the application. - An internal threat could be developed by an internal employee who could easily access the SQL database and take sensitive information (especially if a threat actor is implementing social engineering tactics). A security implementation of least privilege and role access-control should be in place. - Without prepared statements for SQL query an external threat actor could easily exploit this vulnerability in order to

	start a possible SQL injection attack, in order to gain sensitive information and control of the Database.
V. Vulnerability analysis	List 2 vulnerabilities in the PASTA worksheet that could be exploited. • <i>Unsecure Payment information processes</i> • <i>No prepared statements in action for SQL queries</i> • <i>No MFA or more secure login processes in action</i>
VI. Attack modeling	Sample attack tree diagram As we can see from the diagram a threat actor could easily exploit the SQL queries without properly prepared statements by trying SQL injection attacks, leading to obtaining sensitive data and even high privilege roles in order to take control of the Database. The other option could be Session hijacking as an attack vector, this is because MFA and more secure login processes are not in place and a threat actor could easily steal a session ID and obtain sensitive information and access data by stealing login credentials.
VII. Risk analysis and impact	List 4 security controls that you've learned about that can reduce risk. 1. A backup database. 2. Prepared statements before SQL queries. 3. MFA controls for login access. 4. Access-role controls in place for querying the Database. 5. Encryption and Hashing of sensitive data like payments information and credentials.
